

1) A company hires you to test its network but gives you only a one-line email authorization with no defined scope.

Ans:-

As an ethical hacker, I should not exploit the Vulnerability because it is outside the agreed scope of the Penetration test. Ethical hacking must always be performed with proper authorization and within the limits.

The on-line email gives permission to test the network but it does not clearly define which systems can be tested. If I exploit a vulnerability in a system that is not included in the authentication, it could be considered.

Instead of exploiting the vulnerability, I would follow:

⇒ Stop Testing that system immediately once I realize it is outside the agreed scope.

⇒ Document the vulnerability with evidence such as screenshots, logs without causing damage.

⇒ Inform the client immediately about the discovered vulnerability.

⇒ Resume testing only after receiving proper authorized and an updated Scope of work.

This Approach follows the main principle of Ethical hacking:

⇒ Authorization: Test only systems for which permission has been granted

⇒ Legality: Avoid any activity that could be considered illegal or unauthorized.

⇒ Do No Harm: Do not exploit vulnerabilities privately could damage systems.

Responsible Disclosure: Report vulnerability privately to the client and allow them to fix the issue before sharing any information.

Professional Integrity: An ethical hacker acts honestly, respects client agreements and follows industry standards.

Conclusion:

An Ethical hacking should not exploit an out-of-scope vulnerability to prove its impact. The correct action is to stop testing.

2) You are conducting a penetration test and discover that the client's production database contains real customer financial data.

Ans:

⇒ When performing a penetration test, the first responsibility of an ethical hacker is to protect the client's data. Since the production database contains real customer financial information, I must ensure that my testing does not damage

⇒ Although the test plan included exploiting a not fully SQL injection vulnerability, I should not fully exploit it on the live production database.

Steps to proceed safely:

* Confirm the scope and Rules

allow testing on the production database.

is specifically authorized. Exploitation of SQL injection

minimize Risk:

⇒ Use safe SQL injection that only confirms the vulnerability.

Minimize Risk:

⇒ Use Safe SQL Injection technique that only confirm the Vulnerability.

⇒ Avoid commands that modify, delete, or corrupt customer data.

⇒ Mask or hide confidential information if screenshots are required.

Inform The Client Immediately:

⇒ Report the critical vulnerability to the client as soon as it is confirmed.

⇒ Explain the possible risks, such as unauthorized access to financial records.

Recommend Fixes:

⇒ Use parameterized queries (prepared statements)

⇒ Validate and sanitize user input.

⇒ Apply the principle of least privilege for database accounts.

3) During a Black-Box penetration test, you accidentally trigger a denial-of-service (DoS) condition on a live Production Server.

Ans:

A black-box Penetration test is performed without prior knowledge of the target system. Even though the tester has limited information, the main responsibility is to avoid disrupting the client's business operations. Accidentally causing a Denial-of-Service (DoS).

What should have been done to prevent the outage?

1. Define clear Rules of Engagement (RoE):

⇒ Before the test, agree with the client on which techniques are allowed.

⇒ Confirm whether DoS testing is permitted or prohibited.

2. Understand the target Environment

⇒ Identify whether the target is a Production or testing Environment.

Use Safe Testing methods:

⇒ Avoid aggressive scanning or high-volume requests that may overload the server.

⇒ Start with low-intensity tests and increase gradually only if approved.

H. Perform Testing During Maintenance Hours:

⇒ Schedule testing during periods of low use

B. Have An Emergency Response plan

⇒ Ensure emergency contact details are available.

⇒ Define procedure for stopping the test immediately if unexpected issues occur.

Conclusion:

⇒ If a DoS condition is accidentally triggered during a penetration test, the ethical hacker should stop testing immediately, notify the client, assist in restoring services and fully document the incident.

4) An Ethical hacker must always perform security testing in a legal, ethical, and controlled manner.

Ans:

An Ethical hacker must always perform security testing in a legal, ethical and controlled manner. If a client asks me not to inform the IT department. It creates several ethical and practical risks.

Ethical And Practical Risks:

1. Misunderstanding by the IT Team:

⇒ The IT department may believe the attacks is from a real hacker.

⇒ They may block my IP addresses, disable accounts or take emergency actions.

2. Business Disruption:

⇒ Security staff may shut down important systems or services.

⇒ This can affect normal business operations and cause financial losses.

Legal Risks:

⇒ Without proper authorization known to relevant stakeholders, my actions could be mistaken for unauthorized hacking.

⇒ This may create legal or contractual issues.

Safety and Severity Risks:

⇒ The IT Team might involve law enforcement or external incident response teams.

⇒ Time and resources could be wasted responding to what they believe is a real cyber attack.

Damage to trust:

⇒ If employees later discover they were secretly tested without proper planning it may reduce trust between management and the IT team.

5) Using a real-world scenario of a bank wanting to test physical and digital security.

Ans:

* A Red Team exercise and a Vulnerability Assessment are both security testing methods, but they have different objectives and approaches.

1. Red Team Exercise:

* A Red Team Exercise simulates a real cyber attack to test the bank's ability to detect, respond and recover from attacks.

Approach:

* Simulate Real Attackers using techniques such as phishing emails, social engineering, physical access attempts, and network.

* Test both physical security (entry into office buildings or server rooms) & digital

Ethics:

- * obtain written permission from senior management.
- * Avoid damaging systems or exposing customer data.
- * Maintain confidentiality of all sensitive information.
- * stop testing immediately if there is a risk of serious harm.

Rules of Engagement (ROE):

- * clearly define the scope of systems & locations.
- * specify allowed attack techniques.
- * set testing dates and Emergency contacts.